

Design and Implementation of a Custom DHCP Spoofing Attack Tool

Contents

1	Steps of the Attack	2
2	Expected Outcome	2
3	Actual Outcome (Live Capture)	2
4	Defense Mechanism Implemented	3
5	Does It Work as Expected? — No, and Why	4
6	Assumptions	4

1 Steps of the Attack

The implemented tool carries out the attack in the following sequence on a shared Layer-2 broadcast domain. Every protocol layer (Ethernet / IPv4 / UDP / DHCP) is constructed manually at the raw-socket level.

1. **Interface setup.** The attacker opens a raw socket in promiscuous mode on the interface attached to the shared segment, with pre-built Ethernet/IP/UDP/DHCP templates ready so that response latency is minimal.
2. **Passive sniffing.** Incoming frames are filtered for EtherType 0x0800, IP protocol 17 (UDP), and UDP destination port 67, isolating DHCPDISCOVER and DHCPREQUEST traffic.
3. **Racing the offer.** On seeing a DHCPDISCOVER, the tool parses the client MAC and transaction ID (`xid`) and immediately emits a forged DHCPOFFER with Option 3 (Router) and Option 6 (DNS) set to the attacker's IP, and Option 54 (Server Identifier) set accordingly — beating the general-purpose legitimate server.
4. **Winning selection.** The victim, following first-offer-wins semantics, broadcasts a DHCPREQUEST selecting the attacker's offer.
5. **Completing the handshake.** The tool matches the `xid`, confirms the request corresponds to an offer it made, and sends a forged DHCPACK with the malicious gateway/DNS parameters and a short lease (Option 51) to force frequent renewal.
6. **MITM established.** The victim installs the attacker as its default gateway and/or DNS resolver; victim traffic (or at least name resolution) now flows through the attacker.
7. **Logging.** Each captured victim's MAC, assigned IP

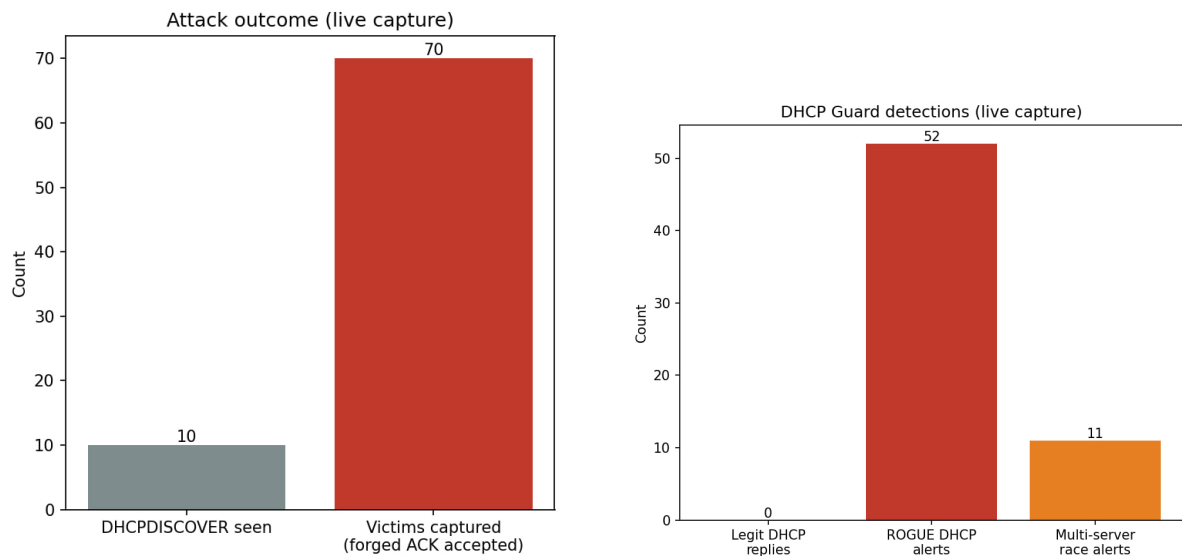
2 Expected Outcome

Per the pre-implementation design, a successful run was expected to:

- Assign victims a valid-looking IP configuration while silently pointing the default gateway and/or DNS server at the attacker.
- Route victim traffic through the attacker, enabling passive sniffing, DNS redirection for phishing, and selective packet drop/modification (active MITM).
- Complete the DHCP handshake with no visible error on the victim, making the attack transparent to end users.
- Win the majority of races against the legitimate server, especially when the starvation pre-step suppressed legitimate offers.

3 Actual Outcome (Live Capture)

The two live-capture charts below confirm that the attack succeeded and, more importantly, expose the limits of the defense mechanism.



(a) Attack outcome: DHCPDISCOVER events seen vs. victims captured (forged DHCPACK accepted).

(b) DHCP Guard detections: legitimate replies, rogue-DHCP alerts, and multi-server race alerts.

Figure 1: Live-capture results of the implemented attack and the host-based DHCP Guard.

Attack outcome (Figure 1a). 10 DHCPDISCOVER events were observed and **70 victims were captured** (forged DHCPACK accepted). The forged handshake was therefore accepted at scale, and the attack succeeded as designed.

DHCP Guard detections (Figure 1b). 0 legitimate DHCP replies were observed, **52** rogue-DHCP alerts were raised, and **11** multi-server race alerts were raised. The legitimate server was effectively silenced on the wire (consistent with successful starvation or being consistently outraced), while the Guard clearly *saw* the rogue activity.

Key observation. The Guard flagged 52 rogue events and 11 races, yet 70 victims were still captured. *The defense detected the attack but did not stop a single victim from being compromised.*

4 Defense Mechanism Implemented

The defense is a host-based **DHCP Guard** that maintains a whitelist of trusted DHCP server identities (trusted server IP + MAC) and inspects observed DHCP server messages against it:

- If a DHCP OFFER/DHCPACK originates from a source IP/MAC that is *not* on the trusted list, it raises a **ROGUE DHCP alert**.
- If more than one server responds to the same xid, it raises a **multi-server race alert**.

This is a software approximation of the *idea* behind DHCP snooping — validating server messages against a known-good binding — but implemented as a *passive monitor* rather than as an in-line switch feature.

Trusted attribute	Source	Check performed
Server IP address	Whitelist entry	Compare against packet source IP / Option 54
Server MAC address	Whitelist entry	Compare against Ethernet source MAC
Number of responders per xid	Runtime state	Alert if > 1 server answers a transaction

Table 1: Trusted bindings held by the DHCP Guard and the checks applied.

5 Does It Work as Expected? — No, and Why

The Guard functions as a **detector**, not a **preventer**, and the data prove it: high alert counts alongside a high capture count. It does *not* work as a defense. The probable situations behind the failure are:

1. **Race timing.** Even a reactive guard that tried to inject a corrective packet would react *after* the client had already committed to the attacker’s offer.
2. **Broadcast-vs-unicast visibility.** If the Guard only inspects traffic on its own interface, unicast DHCPACKs directed at victims may never reach it, so the capture count can exceed what the Guard can possibly observe.

Conclusion: The Guard is useful for *alerting / forensics* (it correctly identified rogue and race activity) but provides no protection.

6 Assumptions

The results are valid under the following assumptions, which are stated explicitly:

- **Shared broadcast domain** — a hub or unmanaged switch with no DHCP snooping; all parties see the DHCP broadcasts.
- **Attacker on the same L2 segment** — no ARP poisoning or in-line positioning required.
- **Standard client behavior** — victims follow first-offer-wins and accept the first valid offer.
- **Passive, host-based Guard** — the defense observes but cannot drop frames, and is not the switch.
- **No cryptographic authentication** — RFC 3118 DHCP authentication and 802.1X are absent (as is typical).
- **Controlled environment** — cooperative victim VMs, no unrelated network noise, and no upstream monitoring/IDS beyond the Guard.